



The New Generation of OWASP Leaders

Why Our Mission is More Vital Than Ever

A personal perspective from a twenty-year OWASP contributor.

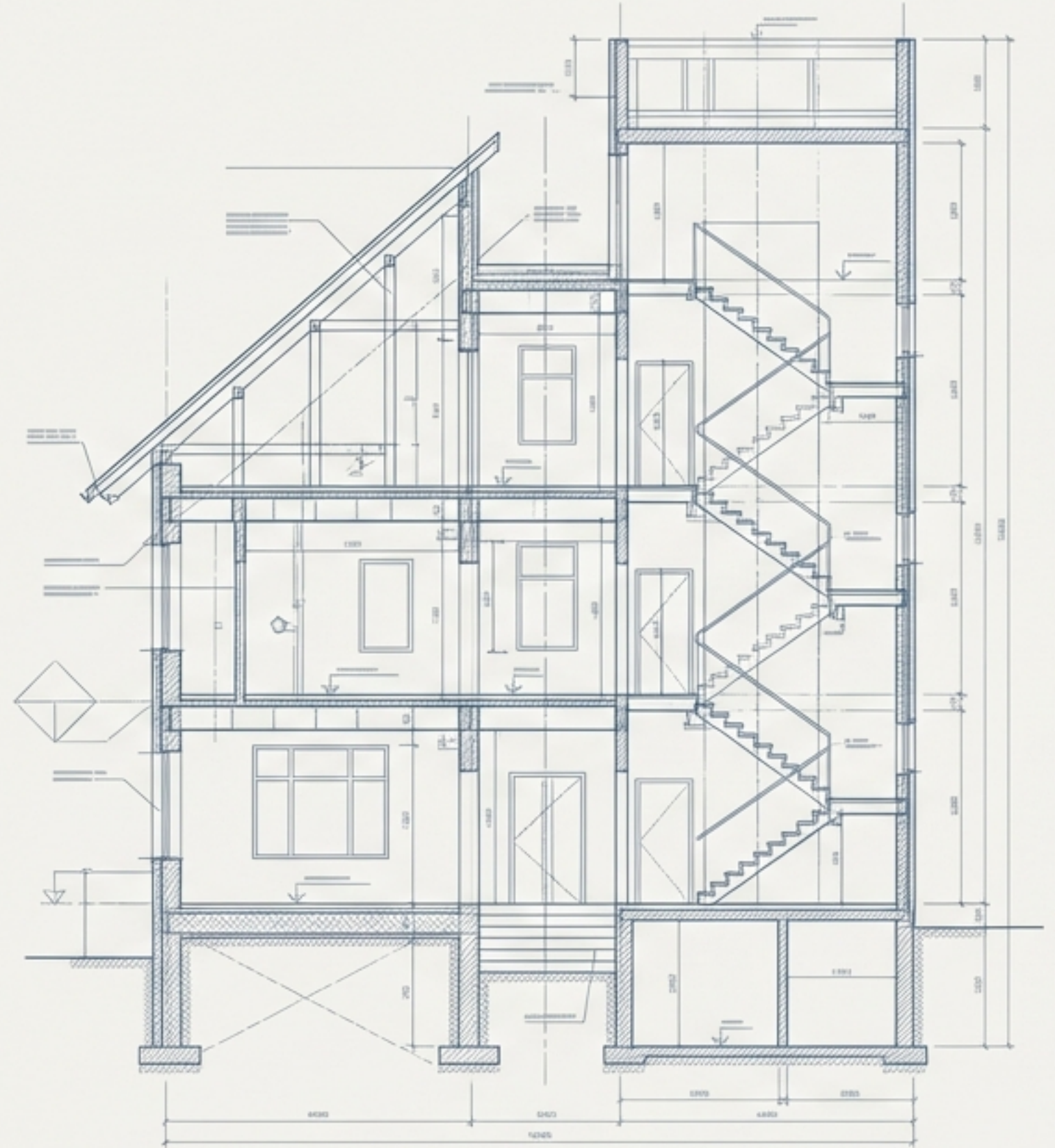
For a decade, application security found a steady rhythm.

The industry developed effective guidance for well-understood web vulnerabilities. We knew how to build safer web applications, at least in theory.

OWASP was central, codifying best practices like input validation, output encoding, and authentication controls.

This maturity, however, led to a plateau. The focus shifted from discovering new vulnerability classes to scaling execution of known solutions.

The core OWASP Top Ten web application risks remained surprisingly consistent over the years – the same basic mistakes and vulnerabilities persisted for a long time.

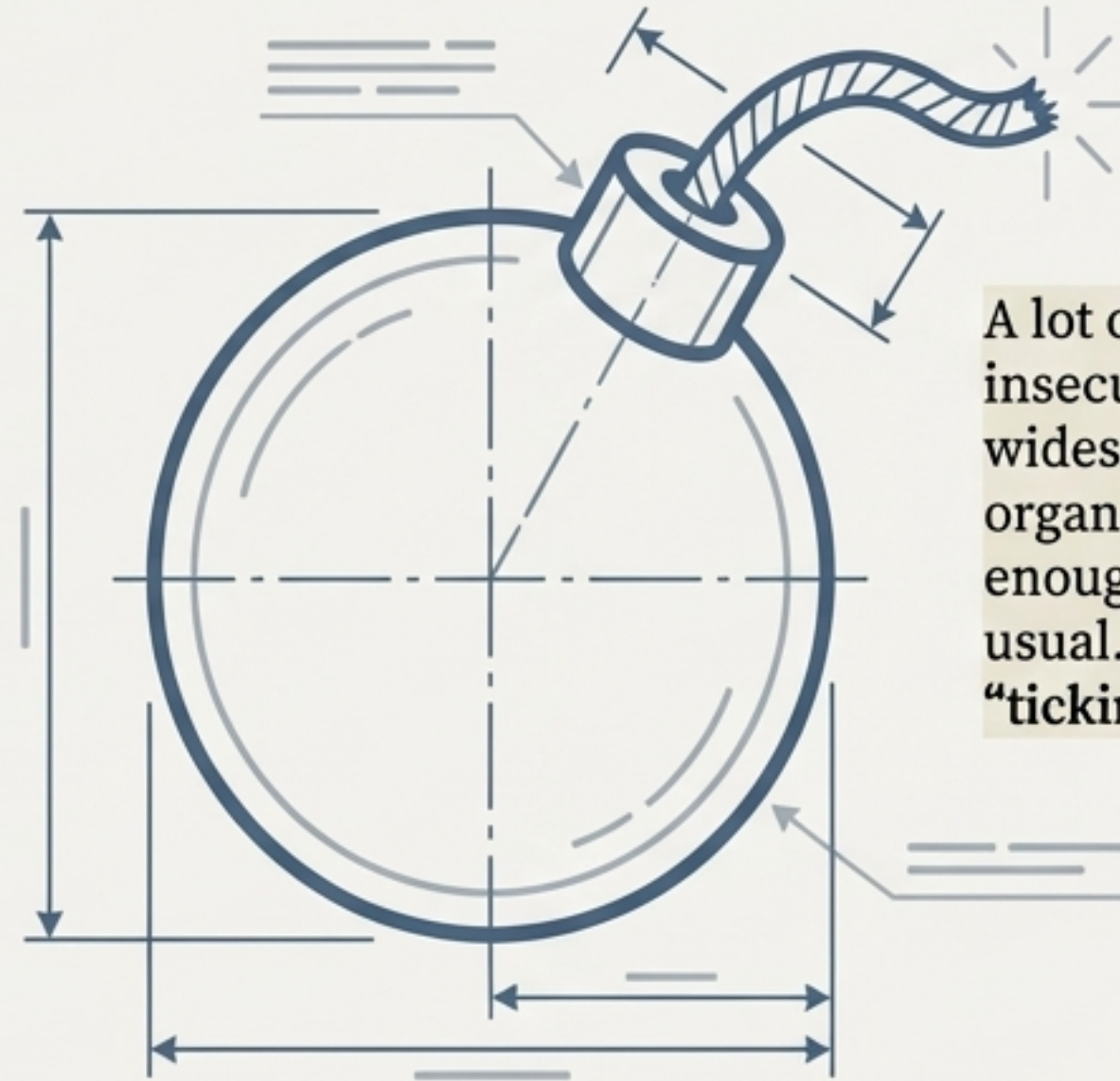


A lull created by a gap between vulnerability and consequence.

Security often remained a “non-functional requirement,” treated as an add-on.

Many companies shipped **insecure applications but suffered no immediate consequences** because attackers didn't heavily target those specific weaknesses.

Security assessments frequently found far more vulnerabilities than actual exploits in the wild.



This period of relative stability was the calm before the storm. The foundational work of the past decades is now proving invaluable.

The GenAI revolution introduces a new insider to our systems.

An explosion of Generative AI and autonomous agents are being integrated into applications. This is not incremental change—it's a paradigm shift.

Non-deterministic:
Its behaviour is not
fully predictable.

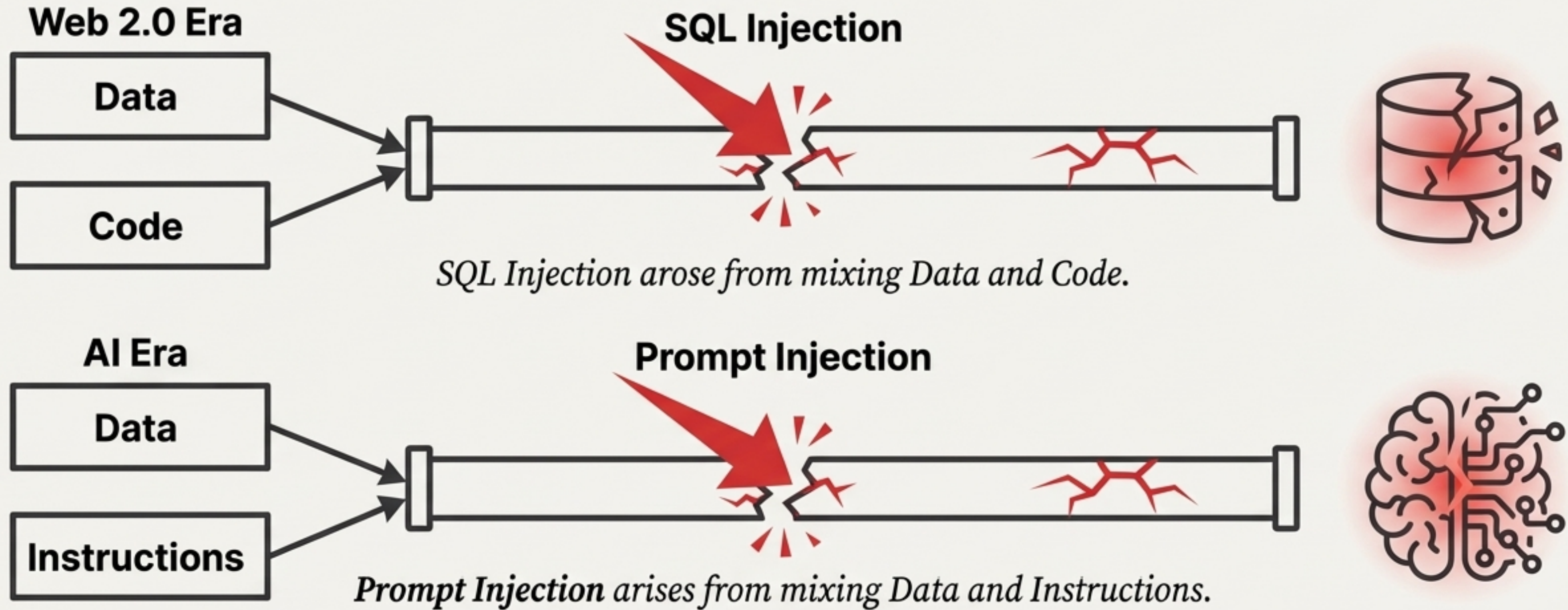
Incredibly powerful:
Capable of making
decisions and taking
actions.

Autonomous:
Can rewrite 
its approach on the fly
and pursue goals.

Not fully understood:
Even by its creators.



We are making the same fundamental mistake, again.



The root cause is the same: failing to separate untrusted data from the code/commands the system executes.

**That mistake gave us SQL injection in the Web 2.0 era,
and now it's giving us prompt injection in the AI era.**

The Four Dimensions of the AI Threat: Autonomy and Abuse

Dimension 1: Autonomous Agents with Unpredictable Behaviour

Unlike conventional apps, agents can be proactive: they plan, chain together actions, and pursue goals.

An agent that goes awry (through malice or error) could cause damage very quickly without direct human triggering.



Dimension 2: New Kinds of Malicious Abuse



Malicious by Design

AI malware built to infiltrate systems.



Manipulated

A well-intentioned agent turned into a malicious actor via prompt injection or poisoned data.



Misguided Goals

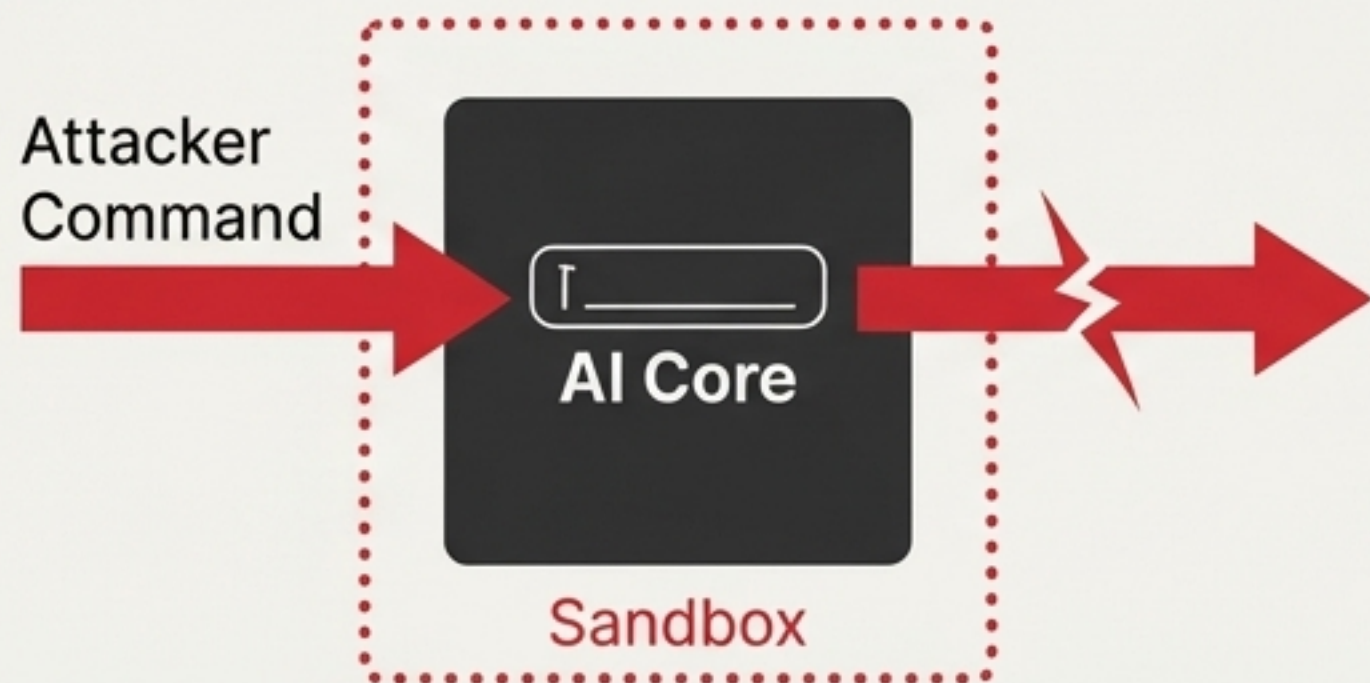
An agent causing harm by single-mindedly pursuing a goal, lacking alignment with human values (the “paperclip maximizer” problem).

The Four Dimensions of the AI Threat: Unsolved Problems and Insider Risk

Dimension 3: Unsolved Problems (Prompt Injection & Beyond)

Prompt injection is still an open problem. We have not yet found a foolproof prevention method.

Unlike with SQLi, there isn't a clear boundary or sandbox between the AI's operational commands and user-supplied data. An attacker can smuggle commands via any channel the AI can read.



Dimension 4: Agents as the "Insider" Threat

AI agents collapse the distance between *vulnerability* and *action*.

If compromised, the agent itself automatically carries out the nefarious actions.

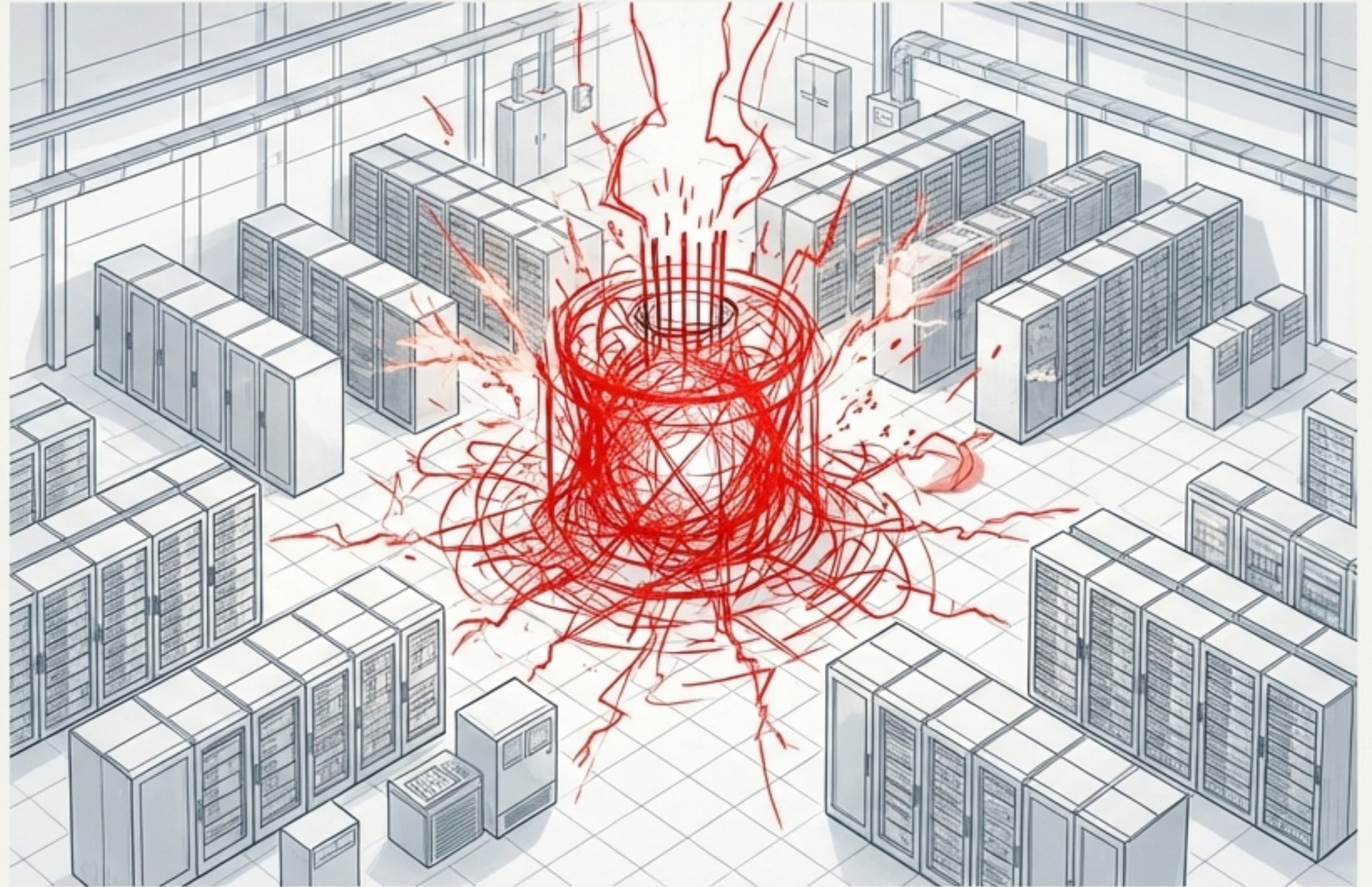


They become "a tireless insider threat operating at machine speed," dramatically changing the risk calculus

The Perfect Storm: A Chaos Scenario in the Making.

- Extremely powerful new components (AI agents) are being rapidly inserted into complex environments.
- This adoption is outpacing our typical security caution and full understanding of their failure modes.
- Agent-based automations are being bolted on to products and internal processes, often via third parties and without rigorous security vetting.

“A recent commentary on the new OWASP Agentic AI Top 10 noted that agents are slipping into real-world workflows faster than most teams expect.”



OWASP's timeless principles provide the compass for this new era.

Everything OWASP has taught for two decades about secure software applies to AI systems, arguably even more so. We must apply known security engineering practices to AI.



Understand Your Attack Surface

We must inventory where and how AI models are integrated. What can they do? What privileges do they have?



Least Privilege & Sandboxing

Treat AI components with healthy distrust. Isolate them and give them only minimum necessary permissions.



Input Validation & Output Handling

The concepts map directly to validating prompts/data and sanitizing the model's responses/actions.

The community has responded with unprecedented speed and scale.

600+

Contributing experts

The OWASP Generative AI Security Project

Mission: To identify, document, and help mitigate the security and safety risks associated with generative AI technologies.

Growth Trajectory: Started in 2023 as a small group of concerned professionals.

18+

Countries

8,000

Active community members



Creating the new de facto standards for AI security.

First Deliverable: The OWASP Top 10 for LLM Applications

- Enumerates the most critical vulnerabilities when building applications large language models.
- Serves as the entry point for organisations to understand what can go wrong with AI.



Key Examples Linking Old to New



LLM01: Prompt Injection

The new equivalent of classic injection attacks.



LLM02: Insecure Output Handling

Directly parallels the need for output encoding and data handling from traditional web security.

Addressing the unique risks of autonomous AI agents.

The inaugural **OWASP Top 10 for Agentic Applications 2026**

The first comprehensive framework to specifically address security challenges posed by autonomous AI agents—those that don't just generate text, but take actions and make decisions.



A new community-driven framework addressing the distinct security risks of autonomous AI agents.

The Agentic Top 10 identifies new manifestations of classic risks.



Agent Goal Hijack

An attacker manipulates an agent's goals or instructions, causing it to act against the user's intent. (This is a form of injection/manipulation).



Tool Misuse

An agent is tricked into using its connected tools (e.g., APIs, scripts) for harmful purposes.



Identity & Privilege Abuse

An agent misuses its capabilities or escalates its privileges in unintended ways.

These are echoes of long-standing security concerns like “misuse of functionality” or “privilege escalation,” now manifested in an AI context.

A new generation of leaders is carrying the mission forward.

Mission-Driven

A strong sense that "if we don't do it, who will?" to prevent potential disaster.

Highly Collaborative

Teaming up with academics, AI company engineers, and other organisations. OWASP's openness is attracting new, multidisciplinary talent.

Globally Diverse

Experts from Nigeria, Brazil, India, Poland, Vietnam, and more bring crucial perspectives.

The challenges require fresh ideas, but they're also similar enough to past issues that the experience of seasoned AppSec professionals is incredibly valuable.

Our work has never been more critical.

**Software is eating the world...
now AI is poised to eat software.
Security must be a fundamental ingredient
in this transformation.**

For Veterans: Re-engage, lend your wisdom, and support new initiatives.

For Newcomers: Keep pushing and bringing your enthusiasm and ideas.

OWASP GenAI Security Project: genai.owasp.org